ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider Electric Modicon M580 ePAC (BMEP58 standalone / BMEH58 Hot Standby / M580 Safety) · Component type: **Embedded Device (EDR) - programmable automation controller (secure-by-design)** · Target SL = SL 3

Where to work	**EcoStruxure Control Expert**: the CPU **Security screen** (cybersecurity mode **Standard / Secured / Enforced**; Access Control IP allow-list; service enable/disable); the **Security Editor** (user profiles + access rights, application / file-encryption / data-storage passwords, **Certificate Whitelist**); the **Memory Protect** physical input. IPsec + OPC UA via **BMENUA0100**; extra Ethernet via **BMENOC0301**. Syslog on the CPU web page (HTTPS).
Ports / paths	Modbus/**UMAS TCP 502**; **HTTP 80 / HTTPS 443** (HTTPS from FW v4.10; **Enforced** mode = HTTPS-only, 502/UMAS refused); **FTP 21** + **TFTP 69** (disable); **SNMP 161**; **EtherNet/IP 44818**; **OPC UA 4840** (BMENUA0100); IPsec (IKE 500/4500); NTP 123; **Syslog 514/601**. Config over Control Expert (Modbus/UMAS, or HTTPS in Enforced).
Firmware / CVEs	Modicon **M580 ePAC** - BMEP58•040 standalone / BMEH58•040 Hot Standby / **M580 Safety (S)** CPUs. Patch the UMAS/Modbus issues - **CVE-2021-22779 (ModiPwn)**, **CVE-2022-45789**, **CVE-2018-7842** - to firmware **sv4.20+** and enforce the application password. Confirm CPU catalog + firmware in Control Expert; secure-by-design (Achilles L2).
How to read	Default read-only (Control Expert read-only .STU review; read-only HTTPS/Modbus/SNMP). Each row = native step-by-step + command-level external-tool validation + pass. Write/exploit tools = isolated env + written authorization. The M580 is secure-by-design - most rows are Met when Enforced/Secured mode + Security Editor are applied.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the Control Expert project (.STU) + archive (.STA) and .XEF/.ZEF export, **uploaded from the CPU**; the CPU **cybersecurity mode** (Standard/Secured) + application/section protection and Ethernet-services config; the IO/module config; firmware rev; and the CPU diagnostic buffer / SYSLOG.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	In Control Expert enable the **Security Editor** (Tools › Security Editor) so engineering access authenticates per user profile, and set the project **application password** so opening/modifying the program requires it. Set the CPU **cybersecurity mode** to Secured/Enforced (CPU Security screen) - in **Enforced** the controller accepts only secure protocols (HTTPS), so unauthenticated Modbus/UMAS is refused outright. **Test:** open/modify the .STU without the application password -> denied; in Enforced mode a plain Modbus/UMAS connect to 502 -> refused. **Ext. tools:** Control Expert (Security Editor + mode); `nmap -p 502,443,44818 <ip>` (in Enforced, 502 closed/refused).	Per-user Security Editor + application password; Secured/Enforced mode; no unauthenticated program access.	EDR.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.2	Device & software-process I&A	Constrain peers: the CPU Security screen **Access Control** allow-list limits which IPs connect; the Security Editor **Certificate Whitelist** binds trusted engineering clients; **IPsec** (BMENUA0100/BMENOC0301) authenticates cross-device comms; OPC UA (BMENUA0100) uses certificates + RBAC. **Test:** a non-allow-listed IP / non-whitelisted certificate -> refused. **Ext. tools:** `nmap --script modbus-discover -p 502 <ip>`; Wireshark `tls || esp || modbus` (IPsec/HTTPS vs cleartext); Modbus client from a non-listed IP (isolated) -> blocked.	Access-Control allow-list + Certificate Whitelist + IPsec bind authorized peers; rogue peers refused.	
SR/CR 1.3	Account management	In the Security Editor manage user profiles/accounts (create/modify/disable), remove defaults, assign least-privilege profiles centrally; no shared logins. The Security Editor governs who may open/modify/download. **Ext. tools:** Control Expert (Security Editor user/profile export); credential-custody record.	Named least-privilege accounts; no shared/default; centrally managed.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (Security Editor) and a unique device identity (IP / device name on the Ethernet Security tab, CPU serial); no identifier reuse across PLCs. **Ext. tools:** Control Expert (Security Editor + Ethernet config); `nmap --script modbus-discover -p 502`; inventory.	Unique user and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Confirm the **application password**, **file-encryption password** (.STU/.STA/.ZEF), and **data-storage password** (IEEE 1686) are set and strong; review the Security-Editor password policy; change all defaults. **Ext. tools:** Control Expert (password/policy review); store in the credential vault.	Strong app/file/data-storage passwords set (IEEE 1686); defaults changed.	
SR 1.6	Wireless access management	**N/A.** Wired ePAC with no native wireless interface. **Ext. tools:** Confirm no wireless module.	N/A - justification recorded (wired device).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	For **HTTPS** (FW v4.10+), **IPsec**, and **OPC UA** (BMENUA0100), review the certificate configuration (CA-signed / asset-owner PKI, valid, not the default self-signed) and the Security-Editor **Certificate Whitelist**; strong keys (>=2048 RSA / ECC), no weak/expired. **Ext. tools:** `openssl s_client -connect <ip>:443 | openssl x509 -noout -issuer -dates`; `testssl.sh https://<ip>`; OPC UA client (BMENUA0100 policy/cert).	CA-signed/whitelisted certs for HTTPS/IPsec/OPC UA; strong keys; defaults replaced.	
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm Control Expert logon, the web interface, and password entry mask the secret (no cleartext echo). **Ext. tools:** Visual verification at each interface.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Control Expert Security Editor has **limited native lockout**; verify what exists and compensate with the Access-Control allow-list + IPsec + upstream controls. Record the gap if absent. **Ext. tools:** Repeated invalid logins (authorized) to characterize; SIEM failed-auth from the Syslog feed.	Lockout where available; otherwise Partial + compensating (ACL/IPsec/segmentation).	Known limitation.
SR/CR 1.12	System use notification	No native PLC logon banner; enforce the approved use-notification on the Control Expert engineering workstation (Windows GPO) and any SCADA HMI (compensating). **Ext. tools:** EWS `gpresult /h gp.html` (legalnoticetext); HMI banner review.	Approved banner at EWS/HMI (compensating at PLC).	Compensating.
SR 1.13	Access via untrusted networks	Segment the PLC; firewall **502/443/44818/4840**; use **IPsec** (BMENUA0100) or a VPN for cross-zone; enable the Access-Control allow-list; in Enforced mode only HTTPS is accepted; no direct UMAS/Modbus from untrusted networks. **Test:** from an untrusted VLAN, reach 502 -> must fail. **Ext. tools:** `nmap -Pn -p 502,80,443,161,44818,4840 <ip>` from the untrusted side (expect filtered); firewall + Access-Control review.	PLC unreachable from untrusted networks; brokered via IPsec/VPN + ACL.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	In the Security Editor confirm per-user **access rights** (read / modify / debug / adjust / configure / security) follow least privilege; the **Memory Protect** input blocks download regardless of login. **Test:** as a read-only user, attempt a download/config change -> denied. **Ext. tools:** Control Expert (access-rights review); attempt a privileged action as a read-only user (isolated).	Least privilege enforced per access right; privileged actions denied.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the Control Expert laptop, the CPU **SD memory card**, and USB/console; removable-media policy on the EWS; only authorized project files (.STU/.STA) loaded. **Ext. tools:** EWS removable-media GPO; physical inspection of the SD/USB.	SD/USB + engineering media controlled; only authorized media used.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code; confirm only the compiled application + signed firmware run and no untrusted DTM/add-on content executes; the file-encryption password protects the project. **Ext. tools:** Control Expert (project / DTM review).	Only the trusted compiled application runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	No PLC-side idle lock; enforce workstation lock on the Control Expert EWS (OS screen lock/GPO). **Ext. tools:** EWS inactivity-lock GPO review.	EWS auto-locks on inactivity (compensating at PLC).	Compensating.
SR/CR 2.6	Remote session termination	Confirm engineering (UMAS/HTTPS) connections can be dropped (Control Expert disconnect) and idle sessions close on the CPU timeout; the application-password **reservation** + Access-Control allow-list limit who can reconnect and prevent conflicting simultaneous programming. **Ext. tools:** Control Expert (connection status / reservation); Wireshark (session teardown).	Sessions terminable on demand and on inactivity; concurrency bounded via reservation.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Confirm **Syslog** security event logging is on: events are stored on the CPU in non-volatile memory (downloadable from the CPU web page over HTTPS) and forwarded to the SIEM; events (logins, program changes, mode change, security) carry the Security-Editor user identity. **Test:** make a program change -> a Syslog event with the user + time appears (CPU web page + SIEM). **Ext. tools:** Syslog listener (`nc -lu 514`); CPU web page (HTTPS) Syslog download; SIEM search.	Security events logged with user + time; stored on-CPU and forwarded to the SIEM.	
SR/CR 2.9	Audit storage capacity	The on-CPU Syslog buffer is finite - forward to the SIEM for retention and confirm the SIEM alerts if forwarding fails so events are not silently lost. **Ext. tools:** SIEM retention + source-silent alert review.	Events offloaded/retained; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm NTP time sync via the CPU/NOC (authenticated where supported) so Syslog/diagnostic timestamps are accurate and correlate. **Ext. tools:** Control Expert time config; `nmap -sU -p 123` / Wireshark `ntp`.	Accurate synced time; consistent timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control the CPU physical interfaces: the **SD-card slot**, USB/console, and RESET; keep the CPU in a locked panel; wire and activate the **Memory Protect** input (configured %I bit) so download/online-modify is inhibited when set; disable unused services. **Ext. tools:** Physical inspection; Control Expert (Memory Protect input active; unused services off).	Physical/diagnostic interfaces controlled; Memory Protect active; unused services disabled.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Use secure protocols: set **Enforced** mode so only HTTPS is accepted (Modbus/UMAS refused), or in Secured mode enable **IPsec** (BMENUA0100/BMENOC0301) + **HTTPS** and disable HTTP/FTP/TFTP; the application password protects UMAS integrity. Confirm in-scope links are encrypted, not cleartext. **Test:** capture the engineering/SCADA links -> HTTPS/IPsec, no cleartext UMAS on critical links. **Ext. tools:** Wireshark `tls || esp || modbus`; `testssl.sh https://<ip>`; `nmap -p 21,69,80 <ip>` (cleartext services closed).	In-scope comms IPsec/HTTPS-protected; cleartext services disabled (Enforced = HTTPS-only).	
SR/EDR 3.2	Protection from malicious code (component)	Confirm only **Schneider-signed firmware** runs; enable **data memory protection** (FW V3.20+) and the CPU **Memory Protect** input; the application + file-encryption passwords protect the project. Patch to sv4.20+. **Ext. tools:** Unity Loader / Control Expert (firmware signature/version); se.com checksum; Schneider SEVD advisory.	Only signed firmware runs; memory protection on; project integrity protected; CVE-patched.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: cybersecurity mode (Secured/Enforced), Security Editor, Access-Control allow-list, Certificate Whitelist, IPsec, Memory Protect, and disabled services, against the hardening baseline; compare the .STU. **Ext. tools:** Control Expert compare vs baseline; `nmap -p 21,69,80,161,502 <ip>` (confirm disabled services off).	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm program/config integrity: application + file-encryption passwords + Memory Protect prevent unauthorized change; archive the encrypted .STU/.STA and use change detection. Compare online-vs-offline. **Ext. tools:** Control Expert (online-vs-offline compare); `certutil -hashfile app.sta SHA256` for drift.	Program integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Patch the UMAS/Modbus CVEs (ModiPwn) and confirm the CPU tolerates malformed UMAS/Modbus/EtherNet-IP frames without faulting. **ISOLATED only:** fuzz on a bench CPU and watch scan/CPU/connection health. **Ext. tools:** UMAS/Modbus fuzzer (`boofuzz`) on a bench CPU; Wireshark; Control Expert diagnostics; Nessus/OpenVAS for known CVEs.	Patched against known CVEs; no crash/major fault on malformed input.	Do NOT fuzz an in-service CPU.
SR/CR 3.6	Deterministic output	Verify configured fail-safe behavior: output-module fallback (hold-last / preset) on CPU STOP or comm loss, and the CPU behavior on fault, so outputs assume a defined safe state (and the Safety CPU's safe state where applicable). **Ext. tools:** Control Expert (I/O fallback config); simulate CPU STOP / comm loss -> defined output state.	Outputs go to a defined/fail-safe state on fault, STOP, or comm loss.	
SR/CR 3.7	Error handling	Confirm graceful application + system fault handling (system words/bits %S, diagnostic buffer, defined fault response) without loss of control or info leak. **Ext. tools:** Control Expert (diagnostics / system words; fault behavior review).	Graceful fault handling; no crash, unsafe state, or info leak.	
SR/CR 3.8	Session integrity	Where IPsec/HTTPS is applied (or Enforced mode), sessions are integrity-protected against replay/hijack; the application password protects UMAS integrity on engineering links. **Ext. tools:** Wireshark (IPsec/TLS session inspection).	Sessions integrity-protected on secured links; replay/tamper prevented.	
SR/CR 3.9	Protection of audit information	Protect the Syslog transport (TCP; TLS where supported) and the SIEM store; restrict access to the on-CPU Syslog/diagnostic data (HTTPS + Security-Editor rights) so records cannot be altered/deleted. **Ext. tools:** SIEM access review; CPU web-page (HTTPS) access control; syslog transport check.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware only with **Schneider-signed** firmware via Unity Loader / Control Expert; the CPU validates the signature; plan a maintenance window with rollback to the prior signed version; apply the CVE-fix firmware (sv4.20+). **Ext. tools:** Unity Loader (signed update/verify); se.com checksum + SEVD advisory.	Signed firmware updates only, CVE-patched, with a controlled update + rollback path.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the CPU in a locked/sealed panel; control the SD memory card, USB/console, and RESET; Memory Protect + Syslog record config/firmware/mode changes as tamper evidence; seal where required. **Ext. tools:** Physical inspection (panel/seal, SD, Memory Protect); Syslog / Control Expert change review.	Panel locked/sealed; interfaces controlled; Memory Protect set; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The CPU accepts only Schneider-signed firmware (product-supplier root of trust); confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Test:** attempt to load an unsigned/tampered firmware on a bench CPU -> rejected. **Ext. tools:** Unity Loader (signature verify); isolated unsigned-image attempt -> rejected.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 3.13	Provisioning asset-owner roots of trust	Confirm the asset owner can provision/manage its own certificates for HTTPS/IPsec/OPC UA (BMENUA0100 + customer PKI) and the Security-Editor **Certificate Whitelist**; else record the compensating control. **Ext. tools:** Control Expert (Certificate Whitelist); BMENUA0100 certificate/PKI config review.	Asset-owner certificate provisioning supported/verified.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the CPU validates signed-firmware integrity before execution (secure-by-design, Achilles L2); no unsigned/tampered firmware runs. Capture firmware version + signature status. **Ext. tools:** Control Expert / Unity Loader (firmware version/signature status).	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, clear the CPU application/memory (Control Expert memory reset / firmware clear) and wipe/destroy the **SD card** so project logic and configuration are not recoverable. **Ext. tools:** Control Expert (clear memory); SD-card sanitize/destroy.	Sensitive project/config data purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Confirm HTTPS (TLS 1.2/1.3) and IPsec use strong parameters; the file-encryption + data-storage passwords protect project/data at rest; disable weak/legacy protocols and the cleartext services. **Ext. tools:** `testssl.sh https://<ip>:443` / sslyze; Wireshark (IPsec).	Strong TLS/IPsec; project/data encrypted at rest; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the PLC is in a segmented cell zone; the **Access Control** allow-list + firewall + IDMZ restrict UMAS/Modbus/EtherNet-IP/OPC UA at the boundary; NOC modules enforce the boundary; only approved flows cross; VPN/IPsec for cross-zone. **Ext. tools:** `nmap -p 502,80,443,161,44818,4840 <ip>` per zone; firewall + Access-Control review.	PLC segmented; only approved flows cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Single-purpose controller with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services on the PLC.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose PLC; no separable applications to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm the on-CPU **Syslog** events are readable/exportable (CPU web page over HTTPS) and forwarded to the SIEM; a passive OT IDS (Modbus/UMAS-aware) on the cell segment gives continuous monitoring. **Ext. tools:** CPU web page (HTTPS) Syslog export; Syslog listener; passive OT IDS (Claroty/Nozomi/Dragos).	Events accessible/exportable and monitored in near-real-time.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: Enforced/Secured mode disables unused services (FTP/TFTP/HTTP/EtherNet-IP/SNMP/DHCP-BOOTP), CPU connection limits + cell-firewall rate-limiting bound floods, and **Hot Standby (BMEH58)** provides availability. Monitor scan time under load. **Ext. tools:** ISOLATED bench: `hping3 --flood -p 502 <ip>` / Modbus storm; Control Expert (scan time / connection count).	PLC keeps controlling under load; unused services off; HSBY where critical.	
SR/CR 7.2	Resource management	Confirm the CPU bounds resource exhaustion (connection limits, CPU load/scan-time headroom) so a single flood cannot deny control; monitor scan time and connection count. **Ext. tools:** Control Expert (CPU load / scan time); traffic generator (ISOLATED).	Resources bounded; no exhaustion-based loss of control under load.	
SR/CR 7.3	Control system backup	Save the encrypted **.STU/.STA** project + SD-card image (versioned, offline); test a restore on a spare CPU; verify Hot Standby failover where used. **Ext. tools:** `certutil -hashfile app.sta SHA256`; Control Expert restore (lab); HSBY failover test.	Verified project + SD backup; restore/failover tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Verify the cybersecurity mode (Secured/Enforced) is applied and settings match the Schneider hardening baseline; **disable all unused services/protocols** (FTP/TFTP/HTTP/SNMP/EtherNet-IP/DHCP-BOOTP), enable the Access-Control allow-list, and activate Memory Protect. **Ext. tools:** Control Expert (Security screen / services); `nmap -sTU -p 21,69,80,161,502,44818 <ip>` (only required reachable).	Secured/Enforced applied; only required services enabled; baseline met.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Capture the CPU catalog (BMEP58•040 / BMEH58•040 / Safety), firmware, and modules (NOC/NUA/RIO) via Control Expert so vulnerabilities track against Schneider SEVD / CISA advisories. **Ext. tools:** `nmap --script modbus-discover -p 502`; Control Expert inventory; Schneider SEVD feed.	Complete CPU/firmware/module inventory captured; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
EcoStruxure Control Expert	Native config & protection review (all FRs)	Open the .STU read-only; CPU Security screen (mode Standard/Secured/Enforced, Access Control, services); Tools › Security Editor (profiles/access rights, app/file/data-storage passwords, Certificate Whitelist); Memory Protect input; firmware. Export as the baseline.	Read/authorized project copy.
Unity Loader	Signed firmware update & provenance (3.2, 3.10, 3.12)	Update the CPU to CVE-fixed signed firmware (sv4.20+) from a Schneider-verified file; confirm signature/version; keep the prior version for rollback.	Maintenance window.

Tool / method	Verifies	How to use — steps / example	Constraints
nmap	Port/service exposure, Modbus ID & segmentation (1.x, 3.1, 5.x, 7.6, 7.8)	`nmap -p 502,80,443,161,44818,4840,21,69 <ip>`; `nmap --script modbus-discover -p 502 <ip>`; scan per zone; in Enforced mode confirm 502/cleartext closed.	Read-only; authorized.
testssl.sh / sslscan / openssl	HTTPS/IPsec cert & TLS strength (1.8, 3.1, 4.3)	`testssl.sh https://<ip>:443`; `openssl s_client -connect <ip>:443 | openssl x509 -noout -issuer -dates` (FW v4.10+).	Read-only.
Wireshark / tcpdump	Comms integrity & identity (1.2, 3.1, 3.8)	SPAN/tap; filter `modbus || tls || esp`; confirm IPsec/HTTPS on in-scope links and whether UMAS/Modbus is cleartext.	Passive; SPAN/tap only.
Modbus / UMAS client (isolated)	Unauth-protocol / ModiPwn & authz tests (1.2, 2.1, 3.5)	From a non-allow-listed IP attempt a Modbus/UMAS connect/write -> blocked; confirm the app password + Enforced mode refuse unauthenticated writes and CVEs are patched.	ISOLATED for write tests; authorization.
Syslog listener + SIEM	Security-event forwarding (2.8-2.10, 6.x)	`nc -lu 514` / rsyslog to confirm the CPU forwards security events; also download Syslog from the CPU web page (HTTPS); trigger a program change and verify.	Coordinate with SIEM team.
Passive OT IDS (Claroty / Nozomi / Dragos)	Monitoring & inventory (6.2, 7.8)	Passively observe the cell for asset inventory, UMAS/Modbus exposure, and anomalies.	Passive only.
UMAS/Modbus fuzzer / hping3	Input validation & DoS resilience (3.5, 7.1)	`boofuzz` Modbus/UMAS on a bench CPU; `hping3 --flood -p 502 <ip>` storm; watch scan time + connection state.	ISOLATED bench; written authorization.
Nessus / OpenVAS + Schneider SEVD	Known-CVE scan incl. ModiPwn (3.2, 3.5, 7.8)	Careful/authenticated scan for known Modicon CVEs; cross-check Schneider SEVD advisories and required firmware (sv4.20+).	ISOLATED/representative; authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.